

Termin 7 – Technische Resilienz I

Backup-Strategien, Disaster Recovery und Notfalltests

Prof. Dr. Dirk Loomans

29. September 2026

Vorlesungsskript • Grundlagen der Resilienz • Cyber Security Management (B.Sc.), 1. Semester • Hochschule Mainz

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Leitfrage

Wie stellen wir sicher, dass wir Systeme und Daten auch unter Worst-Case-Bedingungen zuverlässig wiederherstellen können?

Lernziele

Nach diesem Termin können Studierende

- Bedeutung und Funktionsweise von Backups, Disaster Recovery und Notfalltests erklären – und warum technische Resilienz mehr ist als „ein Backup haben“,
- Backup, Archiv und Redundanz unterscheiden,
- Backup- und DR-Strategien vergleichen und Risiken in der Praxis identifizieren,
- die Rolle von Tests für die tatsächliche Wiederherstellbarkeit beurteilen.

Fachinhalte

Rückblick

Rollenstruktur (CISO, SOC, CERT, DPO, BCM, IT Ops, Management), Kommunikation und Eskalationslogik, Konfliktzonen und Governance-Lösungen. Resilienz entsteht durch Klarheit, Vertrauen und Informationsfluss. Jetzt folgen die technischen Mechanismen, die das Fundament bilden.

Warum Backups unverzichtbar sind

Backups sind die letzte Verteidigungslinie. Sie greifen, wenn alle vorgelagerten Schutzmechanismen versagt haben, und stellen einen historischen Zustand wieder her. Fehlerquellen: **Ransomware, Insider-Angriffe, Hardware-Ausfälle, menschliche Fehler** und Softwarefehler.

Moderne Ransomware-Kampagnen versuchen gezielt, Backup-Repositories zu kompromittieren, Snapshots und Shadow Copies zu löschen, Backup-Server zu übernehmen und Zugangsdaten von Backup-Administratoren zu stehlen. Backups sind deshalb ein zentrales Security-Control: Sie müssen **manipulationssicher, isoliert und wiederherstellbar** sein. Ohne funktionierende Backups drohen Wie-

deraufbaukosten, Haftungs- und Reputationsschäden, wochenlange Unterbrechungen und kompletter Datenverlust.

Backup vs. Archiv vs. Redundanz

	Backup	Archiv	Redundanz
Zweck	Wiederherstellung vergangener Zustände	Langzeitaufbewahrung, Compliance	kontinuierliche Verfügbarkeit (Hochverfügbarkeit)
Merkmale	zeitpunktbezogen, getrennt vom Produktivsystem	unveränderbar (WORM), stabile Formate, seltener Zugriff	parallele Komponenten (RAID, Cluster, Failover-Paare)
Grenze	kein Langzeitarchiv	kein Ersatz für Systemwiederherstellung	löst keine logischen Probleme – spiegelt Fehler oft nur schneller

Typische Missverständnisse: „Wir haben RAID, also haben wir Backups.“ – „Wir archivieren alles, das reicht.“ – „Unsere Cloud repliziert automatisch alles.“ – „Snapshots sind doch Backups.“

Backups sichern Daten. Archive sichern Dokumentation. Redundanz sichert Verfügbarkeit. Keine dieser Maßnahmen ersetzt die anderen.

Die 3-2-1-1-0-Regel

Ziffer	Bedeutung
3	drei Kopien der Daten (Primärkopie plus zwei unabhängige Backups)
2	zwei unterschiedliche Speichermedien (z. B. Disk und Tape, lokal und Cloud)
1	eine Kopie außerhalb des Standorts (Offsite)
+1	eine Kopie immutable oder air-gapped
+0	null Fehler beim Restore-Test

Die klassische 3-2-1-Regel schützt gegen lokale Katastrophen und Storage-Ausfälle. Die Erweiterung reagiert darauf, dass Angreifer Backup-Infrastrukturen gezielt angreifen: Eine Kopie muss unveränderbar sein – auch für kompromittierte Administratoren –, und **ein Backup ist nur dann ein Backup, wenn der Restore erfolgreich getestet wurde.**

- **Air-Gap:** physisch (Tape wird nur zur Sicherung verbunden) oder logisch (zeitgesteuerte, kontrollierte Zugänge, One-Way-Links). Sehr sicher, verlangt organisatorische Disziplin.
- **Immutable:** WORM-Technologien, unveränderbare Cloud-Objektspeicher, Dateisysteme mit unveränderbaren Snapshots.
- **Medienvielfalt:** Identische Medien schützen kaum gegen Firmwarefehler, Seriendefekte, Brand, Überspannung oder Angriffe auf das Storage-System.
- **Retention:** tägliche, wöchentliche, monatliche und jährliche Aufbewahrung sowie gesetzliche Fristen; häufiger Fehler sind über Jahre gewachsene, inkonsistente Policies.

Backup-Typen

Typ	Sichert	Vorteil	Nachteil
Vollbackup	alle ausgewählten Daten	vollständig, schneller Restore	lange Dauer, hoher Speicherbedarf
Inkrementell	Änderungen seit dem letzten Backup beliebigen Typs	sehr schnell, wenig Speicher, häufig möglich	Restore braucht die ganze Kette; anfällig bei beschädigtem Glied
Differenziell	Änderungen seit dem letzten Vollbackup	Restore aus Voll- plus letztem Differenzbackup	wächst mit der Zeit
Snapshot	Zeitpunktabbild auf Storage- oder Hypervisor-Ebene	sehr schnell, ideal für kurzfristige Rollbacks	hängt am Storage, bei dessen Schaden oft mitbetroffen

Snapshots ≠ Backups. Sie sind Teil einer Verfügbarkeitsstrategie. Cloud-native Backups (Versionierung, Datenbank-Snapshots, regionenübergreifende Replikation) unterliegen dem Shared-Responsibility-Modell. Robuste Strategien kombinieren risikobasiert: wöchentliches Vollbackup, tägliches differenzielles Backup, inkrementelle Sicherungen alle zwei Stunden, Snapshots vor kritischen Updates, monatliche Archive und eine immutable Offsite-Kopie.

Backup-Architekturen

	On-Prem	Cloud	Hybrid
Stärken	volle Kontrolle, geringe Latenz, keine externen Abhängigkeiten	geografische Verteilung, Skalierung, einfache Offsite-Sicherung	schneller lokaler Restore plus Cloud-Offsite-Kopie, Kosten steuerbar
Risiken	Investitionskosten, physische Risiken, Katastrophen treffen alles zugleich	Anbieterabhängigkeit, Egress-Kosten, Fehlkonfiguration, Shared Responsibility	höhere Komplexität, Governance bei Identitäten, Datenklassifizierung nötig

Air-Gap- und Immutable-Technologien lassen sich in jede Architektur integrieren. **Shared Responsibility:** Der Cloud-Anbieter sichert die Infrastruktur; Daten, Konfigurationen und Zugänge sichert der Kunde. Architekturfragen: Welche Systeme sind geschäftskritisch? Welche RTO/RPO gelten? Wie hoch ist die Änderungsrate? Welche Angriffsvektoren müssen ausgeschlossen werden? Die Architektur passt zum Risiko – nicht umgekehrt.

Zero-Trust-Backup

- Multi-Faktor-Authentifizierung
- Netzwerksegmentierung
- keine „God-Admins“: getrennte Administratorrollen, Least Privilege
- Backup-Server nicht im selben AD wie die Produktivsysteme

Disaster Recovery

Disaster Recovery (DR) ist die Fähigkeit, komplette Systeme und Dienste nach einem schweren Ereignis in definierter Zeit und mit definiertem Datenverlust wieder bereitzustellen. Auslöser: Ransomware, RZ-Ausfall, schwere Cloud-Fehlkonfiguration, Verlust zentraler Storage-Systeme, Strom- oder physische Schäden, Sabotage.

Disaster Recovery	Business Continuity Management
technische Wiederherstellung	organisatorische Betriebsfortführung
Fokus IT-Systeme	Fokus Geschäftsprozesse
RTO/RPO	Business Impact Analysis
Recovery-Pläne	Notfallpläne und Ausweichprozesse

DR = Wiederherstellung, BCM = Fortführung. Robustes BCM braucht funktionierendes DR.

RTO und RPO: RTO = Zeit, RPO = Datenverlust. RTO 4 h verlangt schnelle Verfügbarkeit, RTO 0 redundante Architekturen (Active/Active). RPO 0 erlaubt keinen Datenverlust, RPO 24 h erlaubt tägliche Sicherungen. Beide bestimmen die DR-Strategie, Kosten und Komplexität.

DR-Strategien

Strategie	Merkmale	RTO/RPO und Kosten
Cold Standby	Systeme ausgeschaltet, Daten regelmäßig kopiert	längste Wiederherstellung, günstigste Variante
Warm Standby	Systeme bereit, aber nicht aktiv; zeitversetzte Replikation	mittlere RTO/RPO
Hot Standby	nahezu vollständige, vorinstallierte Kopie	kurze Recovery, kostenintensiv
Active/Passive	aktives System plus Ersatzsystem, Umschalten im Fehlerfall	abhängig von Umschaltautomatik
Active/Active	beide Systeme gleichzeitig produktiv	maximale Verfügbarkeit, höchste Kosten und Komplexität
Multi-Cloud DR	zwei unabhängige Cloud-Umgebungen	schützt gegen Anbietersausfall, hoher Testaufwand

Abhängigkeiten und Reihenfolge: Identitätsdienste (AD) vor Applikationen, DNS und IAM vor allem Weiteren, Storage vor VMs, Middleware vor Anwendungen. Eine falsche Reihenfolge macht DR wirkungslos. Der DR-Plan dokumentiert Schritte, Reihenfolgen, Rollen, Tools, Zugangsdaten, Netzwerkpfade und Notfallkontakte.

Typische DR-Fehler: Restore funktioniert nicht; Dokumentation fehlt oder ist veraltet; Abhängigkeiten sind unbekannt; unrealistische RTO/RPO (RTO 1 h bei täglichem Backup?); DR-Umgebung weicht von der Produktion ab (Versionen, IP-Räume, Zertifikate).

Notfalltests

„Ein Backup, das nicht getestet wurde, ist kein Backup.“, Notfalltests simulieren den Ernstfall, bevor er eintritt, decken Schwachstellen auf, üben Rollen und Abläufe, verbessern die Dokumentation und machen Reaktionszeiten realistisch einschätzbar [1].

Testform	Beschreibung	Geeignet für
Tabletop	Szenarien werden diskutiert, keine Systeme verändert	erste Tests, Sensibilisierung, Eskalationspfade
Technical Dry Run	einzelne Schritte, Restore einzelner Datenbanken oder VMs	Routine, schrittweise Verbesserung
Full Failover	reale Umschaltung, Messung von RTO und RPO	höchster Erkenntnisgewinn, hoher Aufwand und Risiko
Controlled Outage / Chaos Engineering	gezieltes Abschalten, Unterbrechen von Pfaden (z. B. Netflix Simian Army)	Schwachstellen unter realitätsnahen Bedingungen

Erfolgskriterien: vorab definierte Ziele, aktualisierte Dokumentation, gemessene RTO/RPO, umgesetzte Lessons Learned, reproduzierbare Tests. **Häufige Probleme:** fehlende Verantwortlichkeiten, veraltete Pläne, mangelnde Testtiefe, fehlende Testumgebung, beschädigte Backup-Ketten, kein Rollback-Plan, Angst vor Störung des Produkktivsystems. Notfalltests gehören in einen Zyklus aus Planen, Testen, Dokumentieren, Bewerten, Anpassen und Wiederholen (PDCA, OODA).

Mindesterwartung laut Skript: monatlicher Restore-Test, vierteljährlicher Tabletop-Test, jährlicher Full-Failover-Test.

Übung: „Plan the Worst Day,,

Sie sind das neu zusammengestellte Resilienzteam des Rechenzentrums der Hochschule Mainz. Am Wochenende wurde das Hochschulnetz – glücklicherweise nur simuliert – durch einen kombinierten Ransomware- und Datenbankkorruptionsvorfall gestört. Entwickeln Sie in 90 Minuten ein technisches Resilienzkonzept für: (1) Lernplattform (Moodle), (2) Identity Management / Active Directory, (3) E-Mail & Collaboration, (4) Prüfungsdatenbank, (5) Fileservices, (6) Hochschul-Webseite mit CMS.

Teil 1 – Backup-Konzept (ca. 30 Minuten): Welche Daten, wie oft, welcher Backup-Typ? Wie wird 3-2-1-1-0 umgesetzt, wo liegt die Offsite-Kopie, wie wird das Backup gegen Ransomware geschützt, welche Retention gilt? Ergebnis: Tabelle pro System.

Teil 2 – DR-Plan (ca. 30 Minuten): RTO und RPO je System, DR-Strategie, Abhängigkeiten (AD vor E-Mail, DNS vor allem), Wiederherstellungsreihenfolge, zuerst benötigte Infrastruktur (Storage, Netzwerk, IAM). Ergebnis: diagrammatischer DR-Plan mit tabellarischer Priorisierung.

Teil 3 – Notfalltest-Konzept (ca. 30 Minuten): Testarten und Häufigkeit für zwölf Monate, Metriken (RTO-Abweichung, RPO-Erreichung, Datenintegrität, gefundene Schwachstellen), Dokumentation und Umsetzung der Lessons Learned. Ergebnis: Jahres-Testplan mit Erfolgsindikatoren.

Prüfungsrelevante Leitfragen

1. Warum sind Backups eine zentrale Säule der technischen Resilienz, und warum gelten sie als letzte Verteidigungslinie?

2. Worin unterscheiden sich Backup, Archiv und Redundanz, und warum können sie einander nicht ersetzen?
3. Was beschreibt die 3-2-1-1-0-Regel? Was bedeutet die „0“?
4. Erklären Sie Voll-, inkrementelle und differenzielle Backups. Warum sind Snapshots keine Backups?
5. Welche Vor- und Nachteile haben On-Prem-, Cloud- und Hybrid-Backup-Architekturen? Was bedeutet Shared Responsibility?
6. Was ist Disaster Recovery, und wie unterscheidet es sich vom BCM?
7. Definieren Sie RTO und RPO und erklären Sie ihren Einfluss auf die DR-Strategie.
8. Welche DR-Strategien gibt es, und wie hängt ihre Kostenstruktur mit RTO/RPO zusammen?
9. Welche Testarten gibt es, und warum gilt: „Ein ungetestetes Backup ist kein Backup„?
10. Welche typischen Fehler gefährden technische Resilienz, und wie lassen sie sich vermeiden?

Merksatz: Backups retten Daten. Disaster Recovery rettet Systeme. Tests retten den Betrieb.

Vor- und Nachbereitung

Ausblick Termin 8: Zero Trust, Microsegmentation, Cloud Resilience und Network Design.

Material aus dem Archiv

07 Technische Resilienz I/07_Technische Resilienz I.pdf und Skript Sitzung 7 Technische Resilienz I.pdf (mit Übungsanleitung).

Bibliografie

- [1] M. Swanson, P. Bowen, A. W. Phillips, D. Gallup, und D. Lynes, „Contingency Planning Guide for Federal Information Systems“, NIST Special Publication 800-34 Rev. 1, Mai 2010. doi: [10.6028/NIST.SP.800-34r1](https://doi.org/10.6028/NIST.SP.800-34r1).